

Apache Security Headers & Scan Analysis

Complete Step-by-Step Implementation, Troubleshooting & Verification Guide for Kali Linux DVWA

Environment: Kali Linux / Apache 2.4 / DVWA

Target Grade: A / A+ on SecurityHeaders.com

Tooling: mod_headers, Ngrok / Pinggy

1. Executive Summary & Core Concepts

What is a Web Security Header?

HTTP Security Headers are response headers sent by the web server (Apache) instructing the client's web browser to enforce strict security controls. Instead of modifying application code, these headers harden the client browser environment against major web vulnerabilities like Cross-Site Scripting (XSS), Clickjacking, MIME-sniffing, and MITM attacks.

Security Header	Recommended Value	Primary Defense Purpose
Content-Security-Policy (CSP)	<code>default-src 'self' 'unsafe-inline' 'unsafe-eval';</code>	Prevents Cross-Site Scripting (XSS) and unauthorized script execution. Allows DVWA functionality.
X-Frame-Options	<code>SAMEORIGIN</code>	Prevents Clickjacking by restricting framing inside <code><iframe></code> elements.
X-Content-Type-Options	<code>nosniff</code>	Stops browsers from MIME-sniffing response types away from the declared content-type.
Referrer-Policy	<code>strict-origin-when-cross-origin</code>	Prevents sensitive URL path disclosure to external domains during navigation.
Permissions-Policy	<code>geolocation=(), microphone=(), camera=()</code>	Restricts browser API access to sensitive hardware features (Camera, Mic, GPS).
Strict-Transport-Security (HSTS)	<code>max-age=31536000; includeSubDomains</code>	Enforces encrypted HTTPS communication, mitigating protocol downgrade attacks.

2. Apache Configuration Implementation

1 Enable Apache Headers Module

Activate the `mod_headers` module in Kali Linux Apache web server:

```
sudo a2enmod headers
```

2 Apply Global Security Configuration (Recommended Method)

To ensure security headers are applied reliably across all virtual hosts, HTTP/HTTPS ports, and proxy tunnels (such as Ngrok), edit the global security configuration file:

```
sudo nano /etc/apache2/conf-available/security.conf
```

Append the following directive block at the bottom of the file:

```
<IfModule mod_headers.c>
    Header always set X-Frame-Options "SAMEORIGIN"
    Header always set X-Content-Type-Options "nosniff"
    Header always set Referrer-Policy "strict-origin-when-cross-origin"
    Header always set Permissions-Policy "geolocation=(), microphone=(), camera=()"
    Header always set Content-Security-Policy "default-src 'self' 'unsafe-inline' 'unsafe-eval';"
    Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"
</IfModule>
```

Note on `Header always set` vs `Header set` :

Using `always set` ensures Apache delivers these headers even during non-200 responses, redirects (301/302), errors, or reverse-proxied traffic via tunnels.

3 Enable Configuration & Restart Apache

```
sudo a2enconf security
sudo apache2ctl configtest
sudo systemctl restart apache2
```

3. Verification & Troubleshooting Workflow

A. Local Verification (Curl)

Verify that Apache directly outputs all headers on the local machine:

```
curl -I http://localhost
```

Expected Output:

```
HTTP/1.1 200 OK
Server: Apache/2.4.68 (Debian)
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: geolocation=(), microphone=(), camera=()
Content-Security-Policy: default-src 'self' 'unsafe-inline' 'unsafe-eval';
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Type: text/html; charset=UTF-8
```

B. Public Verification on SecurityHeaders.com

Because SecurityHeaders.com cannot scan `localhost` directly, expose your local port 80 to the public internet using Ngrok:

1. Install Ngrok on Kali Linux:

```
curl -sSL https://ngrok-agent.s3.amazonaws.com/ngrok.asc | sudo tee /etc/apt/trusted.gpg.d/
ngrok.asc >/dev/null
echo "deb https://ngrok-agent.s3.amazonaws.com bookworm main" | sudo tee /etc/apt/sources.list.d/
ngrok.list
sudo apt update && sudo apt install ngrok
```

2. Launch Tunnel Bypassing the Interstitial Warning Page:

```
ngrok http 80 --request-header-add "ngrok-skip-browser-warning: 1"
```

Common Pitfall Encountered (Grade F or D):

Free tunneling services like Localtunnel or Ngrok display an anti-phishing landing page to automated crawlers by default. When SecurityHeaders.com scans the URL, it scans the tunnel's warning page instead of your Apache server, resulting in missing headers. Using `--request-header-add "ngrok-skip-browser-warning: 1"` solves this problem.

4. Summary of Diagnostics & Fixes

Issue Encountered	Root Cause	Resolution
Syntax error / \$ServerAdmin typo	Accidental character typed in 000-default.conf	Corrected \$ServerAdmin to ServerAdmin webmaster@localhost
ngrok: command not found	Ngrok package missing from default Kali repos	Installed via official Ngrok APT repo or used alternative SSH tunnel (Pinggy)
Security scan shows Grade F	Scanner evaluated Localtunnel warning page	Added request header bypass parameter to tunnel launch command
Missing headers on HTTPS scan	Headers configured inside HTTP VirtualHost block only	Moved headers block to global security.conf using Header always set

Final Outcome: With global Apache rules enabled and HSTS configured, public security analysis on SecurityHeaders.com yields an **A / A+ Grade**.